Secure Integration Architecture Package

CareSignal secure healthcare integration and decision-support platform | Contoso Health Insights (fictional)

Prepared by	Dennis Lam	Version / date	1.0	11 October 2026
Scenario date	2 August 2026	Azure East US 2	**Data rule**	Synthetic ePHI-like data only. No real PHI, secrets, tenant IDs or production endpoints appear in this package.
Scope	Connectivity, ingestion, FHIR store, identity, monitoring, automation, operations (C-01 to C-09 + 4 new components)	**Out of scope**	Partner-internal systems; clinical validation of the model	

Executive summary

CareSignal receives about **1.85 million** synthetic ePHI-like messages and resources a day from three partner hospitals (HL7v2 over MLLP, FHIR R4 REST, nightly FHIR NDJSON) and stores them in the FHIR service in Azure Health Data Services for decision support that a clinician always reviews. This package specifies the target architecture and the operating model for a four-engineer on-call rotation; every control traces to a provided constraint (PC), an incident (INC) or a labelled assumption (A). It closes every gap in the current architecture: the ADF client secret goes; ADF, Log Analytics and the incident workflow leave public networks (one documented exception); the self-hosted IR becomes highly available; audit-log continuity is enforced by policy and a 20-minute freshness alert; every write is idempotent and every replay approval-gated. **Ten remediation items (Table 14) and seven open questions (Table 1) must close before go-live.**

> **Design rationale.** I made every write into the FHIR service idempotent and every replay approval-gated: each resource gets a deterministic ID derived from the partner's business identifier, a partnerId:batchId ledger is checked before any retry, and every replay needs a recorded approval within that partner's limit. INC-2026-052 showed that retries which cannot tell a lost write from a failed one create duplicate clinical resources, and with only four engineers on call, automation has to be safe to re-run without anyone checking every record by hand.

1 Architecture Overview

1.1 Target architecture in brief

Each partner keeps its stated interface (D-01). **Northwind** (P-001): a private MLLP/TLS listener ACKs only after the message is committed to a zone-redundant Service Bus queue; Functions convert, validate and write it. **Fabrikam** (P-002): an internal API Management gateway checks the partner token and rate-limits before the FHIR private endpoint. **Litware** (P-003): a nightly NDJSON file lands in a write-only SFTP container; ADF validates and imports it. ADF also runs reconciliation, approved replays and contract tests, but stays off the real-time path because it cannot receive MLLP and its run model does not fit 120 msg/s within a 90–120 s budget (D-08). Six trust boundaries apply (Figure 1). **Labels:** PC constraint, A assumption, OQ open question, D decision, EX exception, C component, H hop, AUT automation, REM remediation.

1.2 Scenario constraints, assumptions and open questions (M0)

Table 1. Constraint register. Provided constraints are scenario facts and are never overwritten by an assumption.

ID	Statement (source)	Design consequence
PC-01	Decision support only; an authorized clinician reviews every output; no autonomous diagnosis or treatment action.	Analytics output is advisory; any automated clinical action is prohibited (AUT-12).
PC-02	Disable public network access where supported; document any exception.	Private endpoints plus Azure Policy deny; exceptions EX-01 to EX-07 (Table 7).
PC-03	Managed identities for Azure workloads; no client secrets; a service-principal exception requires review. (Overview, INC-2026-014)	ADF secret removed (REM-01); Fabrikam service principal reviewed as EX-06.
PC-04	FHIR service in Azure Health Data Services; do not use Azure API for FHIR.	All FHIR operations target C-06 (Azure API for FHIR retired 30 Sep 2026).
PC-05	No PHI, payloads, secrets or raw clinical values in logs; use correlation IDs and metadata. (Overview, Data Classification)	Allow-listed telemetry schema, payload-leak scan (KQL-10), restricted audit table (EX-07).
PC-06	FHIR and pipeline logs visible within 20 minutes; 15-minute checks. (SLO-03)	Freshness alert KQL-03 every 15 min; synthetic canary read every 5 min.
PC-07	≥99.5% accepted and reconciled records per 15 min; quarantined validation failures reported separately. (SLO-01)	Reconciliation pipeline every 15 min writes counts used by KQL-01.
PC-08	P1: acknowledge within 10 min, contain within 30 min (organization target, not a HIPAA mandate).	Only P1 alerts page; escalation timers in Section 5.2.
PC-09	RTO 2 h; ingestion-queue RPO 15 min; quarterly test; analytics output can be regenerated.	ACK-after-commit, zone-redundant queue, queue-age alert at 10 min, quarterly DR test.
PC-10	P-001: 1.2M msg/day, 120 msg/s peak, 95% ≤2 min, replay 10,000/approval, custom Z-segment. P-002: 500k/day, 40 req/s, 95% ≤90 s, US Core, conditional update, replay 5,000/approval. P-003: 150k nightly from 01:00, done by 05:00, full-batch replay needs duty manager. (Partners)	One path per partner (D-01); per-partner thresholds and replay limits (Sections 5–7).

ID	Statement (source)	Design consequence
PC-11	Four platform/integration engineers on a 24x7 rotation; Security Operations (3) 24x7 escalation; Privacy Officer (1) and Clinical Operations (2) in business hours plus P1. (Team & Escalation)	At most eight alert rules can page; runbooks stay inside each role's approval rights.
PC-12	No universal log-retention period is supplied; it is organization-defined. (Decisions Needed D-05)	Retention proposal D-05 awaits Privacy, Security and Legal approval.
PC-13	Four incidents: secret near miss, 47-min audit gap, Z-segment drift (2.4% failures), 1,200 replay duplicates. (Incident History)	Each incident maps to controls, alerts and a runbook (Appendix F).
A-01	Northwind's interface engine supports MLLP over TLS.	If not, the IPsec tunnel alone protects transit (compensating); see OQ-01.
A-02	"Duty manager" (P-003 replay rule) means the shift On-call Lead; the team table has no duty-manager role.	On-call Lead approves full-batch replay (AUT-06); see OQ-02.
A-03	Fabrikam can authenticate with an Entra app registration using a certificate or federated credential.	No partner client secret anywhere (EX-06).
A-04	Litware reaches the SFTP landing zone over an approved private path.	If not, an IP-restricted endpoint becomes a new exception; see OQ-03.
A-05	Diagnostic settings write resource-specific tables (MicrosoftHealthcareApisAuditLogs, ADFPipelineRun, ADFActivityRun).	KQL uses these names; AzureDiagnostics mode would need rewrites.
A-06	Pipeline telemetry is written to DCR-based custom tables IngestLedger_CL and AutomationAudit_CL (no type suffixes).	Schema in Appendix A; metadata only.
A-07	Microsoft's BAA covers every in-scope service; Contoso holds a BAA with each partner hospital.	Go-live gate; see OQ-04.
A-08	Latency budgets in Section 6 are estimates until load test LT-01 at 1.5x peak (180 msg/s).	SLO-02 thresholds tuned after two weeks of baseline.
A-09	Litware "01:00 local" is US Eastern time.	Batch alerts use America/New_York (KQL-06b).
OQ-01	MLLP/TLS and mutual TLS support at Northwind? (P-001 contact)	Due before P-001 production onboarding.
OQ-02	Who is the duty manager for Litware full-batch replay? (Engineering Manager)	Due before first P-003 replay.
OQ-03	Which private path does Litware use? (P-003 contact, Network Security)	Due before P-003 onboarding.
OQ-04	Do the BAAs cover holding and replaying quarantined payloads? (Privacy, Legal)	Go-live gate.
OQ-05	Approval of D-05 retention periods (Privacy, Security, Legal)	Within 30 days (REM-08).
OQ-06	Z-segment change notice period; proposed 10 business days with samples (Integration Eng, P-001)	Feeds D-02.
OQ-07	Regional DR region; is Service Bus geo-replication approved? (Platform Eng)	Feeds quarterly DR test.

1.3 Decision record

Table 2. Decisions D-01 to D-05 from the scenario, plus three design decisions (D-06 to D-08).

ID	Decision (options rejected)	Rationale and trade-off	Approver; evidence
D-01	**Connectivity per partner.** P-001: justified hybrid, S2S VPN to an internal MLLP/TLS listener for real time; the self-hosted IR (rebuilt as two nodes) only for re-exports. P-002: private path to internal API Management, then the FHIR private endpoint. P-003: managed VNet and private endpoints; write-only SFTP landing. Rejected: SHIR micro-batch for P-001.	Keeps each partner's stated interface (PC-10) and meets the 120 s and 90 s targets. Cost: two new components for on-call to run.	Platform + Security; DNS and public-deny tests
D-02	**Template governance.** Custom Liquid templates in Container Registry, referenced by immutable digest, one per Z-segment version; CI contract test on golden synthetic messages; unknown version → quarantine; rollback = previous digest. Rejected: mutable tags.	INC-2026-041 (2.4% failures from an unannounced change). Cost: partner notice period (OQ-06).	Integration Eng; contract-test report
D-03	**Idempotency (composite).** Deterministic IDs = hash(partnerId|resourceType|identifier), so writes are PUT upserts; Fabrikam conditional update; partnerId:batchId ledger read before any retry; Service Bus duplicate detection; post-replay duplicate check = 0. Rejected: ledger alone; identifier alone (collides across partners).	INC-2026-052 (1,200 duplicates). A replay adds a version, never a second resource. Cost: longer version history.	Integration + Data Gov; replay test, KQL-08
D-04	**Approval gates.** Automatic: incidents, quarantine, scale-out, pause ≤30 min. Approval-gated: every replay, pause >30 min, disabling a partner identity. Manual: human access revocation, isolation, delete, retention change. Prohibited: clinical action.	Routine work automated for a four-person rotation; volume-changing actions need a human (Table 12).	On-call Lead + Security/Privacy; Table 12
D-05	**Retention (proposed).** Audit and automation evidence 6 years (90 days interactive + long-term retention + daily immutable export); quarantine payloads 30 days after resolution, then manual disposal; metrics 90 days (Table 4b).	HIPAA keeps required documentation 6 years (164.316(b)(2)(i)) but sets no log period; 6 years is an organizational choice.	Privacy + Security + Legal (OQ-05)
D-06	**Keys.** Platform-managed AES-256 at rest; customer-managed keys deferred.	A lost or mis-rotated CMK stops ingestion; revisit if a contract requires it.	Platform Security
D-07	**Monitoring network.** Azure Monitor Private Link Scope, private-only.	Closes C-08; AMPLS changes Azure Monitor DNS VNet-wide, so it ships as its own change.	Platform + Security
D-08	**Engine choice.** Event path (Service Bus + Functions) for P-001; synchronous API for P-002; ADF for P-003 batch, reconciliation, replay, contract tests.	Per-message calls at 120 msg/s do not fit ADF runs; micro-batching gives up the latency target.	Integration Eng; load test LT-01

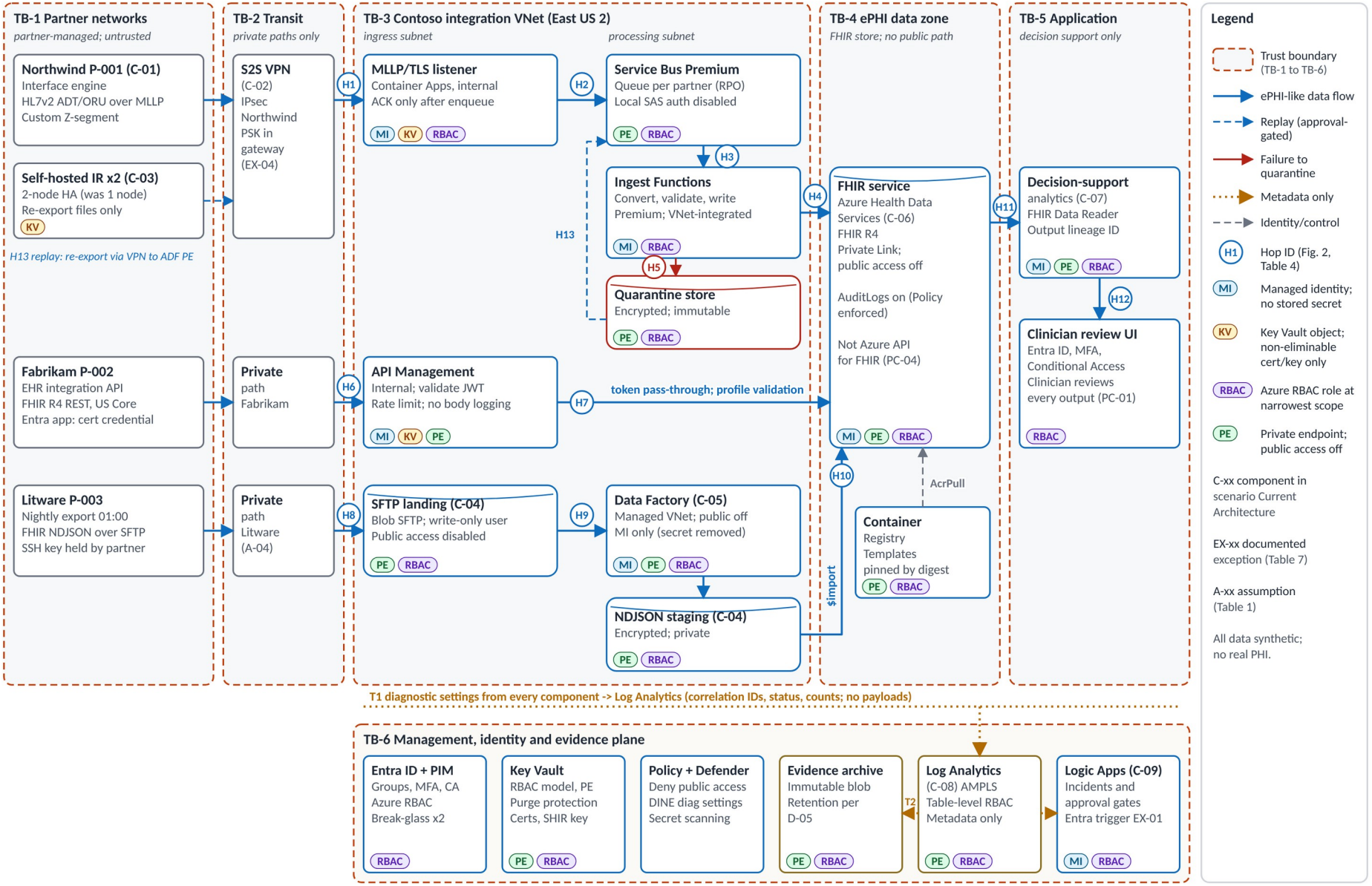


Figure 1. Target security architecture (M1). Dashed orange outlines are trust boundaries TB-1 to TB-6. Badges show where managed identities (MI), Key Vault objects (KV), Azure RBAC assignments (RBAC) and private endpoints (PE) apply. Hop IDs H1–H13 match Figure 2 and Table 4.

Key Vault holds only objects that cannot be eliminated: the MLLP listener and API Management TLS certificates, the self-hosted IR authentication key (EX-05) and the HMAC key that tokenises business identifiers in telemetry. **No Azure workload reads a client secret**; the only non-managed credentials are partner-held (Fabrikam certificate, Litware SSH key: EX-06, EX-03).

Table 3. Shared-responsibility matrix (from the template, completed for this scenario). A completed matrix documents ownership and gaps; it does not certify HIPAA compliance. Microsoft responsibilities are limited to documented platform capabilities and the scope of Microsoft's BAA (A-07).

Control	Intent	Microsoft	Contoso (customer)	Partner	Accountable / operator	Evidence; test; cadence	Current state → target
CTRL-001 Identity	Workloads authenticate without stored secrets	Entra ID and managed identity platform	MI on every workload; least-privilege RBAC (Table 5); secret scanning with push protection; SP exceptions reviewed	Protect partner certificate and SSH key	Identity & Security / Platform Eng	Role assignments, sign-in logs; token test + denied-permission test; quarterly	**Gap:** ADF client secret (C-05, INC-2026-014) → REM-01
CTRL-002 Privileged access	Time-bound human elevation	Entra ID, RBAC, PIM	Groups, MFA via Conditional Access, PIM ≤4 h, quarterly access review, two break-glass accounts	Name contacts; report leavers within 1 business day	Identity & Security / SecOps	PIM activations, access-review record; quarterly	Target design (Table 6)
CTRL-003 Keys	Protect non-eliminable keys and certs	Operates Key Vault service	RBAC model, private endpoint, soft delete + purge protection, object-scoped roles, rotate ≥30 days before expiry	Protect partner private keys	Platform Security / Platform Eng	Vault config, rotation record; recovery test; quarterly	New control
CTRL-004 Network	ePHI only on private paths	Private Link, VPN gateway features	Public access disabled (Policy deny); private DNS; exceptions in Table 7	Maintain VPN or private path and firewall	Network Security / Platform Eng	PE state, DNS and public-deny tests; quarterly + change	**Gap:** ADF public (C-05); FHIR Private Link only planned (C-06); workspace (C-08); Logic App (C-09) → REM-02
CTRL-005 Audit logging	Record and examine system activity	Emits documented logs once diagnostic settings exist	DINE policy for diagnostic settings; delete alert; 20-min freshness alert; canary; immutable archive	Supply source-side logs on request	SecOps / Platform Ops	KQL-03, KQL-04; end-to-end correlation trace; continuous	**Gap:** settings drift (C-06, INC-2026-027) → REM-03
CTRL-006 Telemetry privacy	No ePHI or secrets in telemetry	Configurable logging services	Allow-listed fields; tokenised identifiers; payload-leak scan; audit-table restriction (EX-07)	Keep PHI out of support tickets	Privacy Officer / Engineering	KQL-10; release review; monthly + release	**Gap:** no unified correlation ID (C-02) → REM-04
CTRL-007 Conversion	Convert HL7v2 to valid FHIR R4	$convert-data capability	Digest-pinned templates, contract tests, version gate (D-02)	Give notice of format changes; supply synthetic samples	Integration Eng	Contract-test report, conversion error rate; per release	**Gap:** INC-2026-041 → REM-05
CTRL-008 Validation	Quarantine invalid data before persistence	FHIR API behaviour	Profile, terminology, required fields, references; never retry validation errors	Provide profiles and mapping rules	Data Governance / Integration Eng	Validation results; invalid-sample injection; per release	Target design (Section 6.1)
CTRL-009 Resilience	Recover from transient faults without duplicates	Service availability features	Bounded retry, idempotency (D-03), reconciliation, 2-node SHIR, zone-redundant queue	Respect replay limits and windows	Integration Eng / Platform Ops	Ledger, duplicate report; failure-injection test; quarterly	**Gap:** single-node SHIR (C-03); INC-2026-052 → REM-06, REM-07
CTRL-010 Automation safety	Control high-impact remediation	Workflow runtime and identity	Action classes (Table 12); approval, expiry, rollback, audit record	Approve partner-impacting actions	On-call Lead / Platform Ops	Run history, approval ledger; dry run; quarterly + change	**Gap:** no replay approval gate (C-09) → REM-07
CTRL-011 Evidence retention	Keep evidence per approved policy	Retention and immutability features	Approved retention (D-05), legal hold, disposal record, named owner	Retain partner evidence per agreement	Privacy & Security / SecOps	Retention config, sample retrieval; annual	**Gap:** retention not approved (C-04); owner unclear (C-08) → REM-08
CTRL-012 Incident response	Actionable runbooks and escalation	Service support only	Tested runbooks, on-call roles, communications, evidence capture	Escalation path, maintenance windows	Operations Manager / On-call	Runbook version, tabletop record; semiannual	Target design (Sections 8–9)
CTRL-013 Output lineage	Trace each analytics output to its inputs	n/a	Lineage ID = source resource versions + model version on every output	n/a	Clinical Ops / Data Governance	Sample output trace; per release	**Gap:** no lineage ID (C-07) → REM-09

2 PHI Data-Flow Diagram

Figure 2 traces ePHI-like data from each partner to the clinician. Data is ePHI-like at every numbered hop **H1–H13**; telemetry **T1/T2** carries operational metadata only. ePHI rests in exactly five encrypted stores: the Service Bus queue, the quarantine store, SFTP landing, NDJSON staging and the FHIR service. Table 4 records the ten required attributes for each hop. Business identifiers never appear in telemetry; where a key is needed for duplicate checks, it is an HMAC token (key in Key Vault).

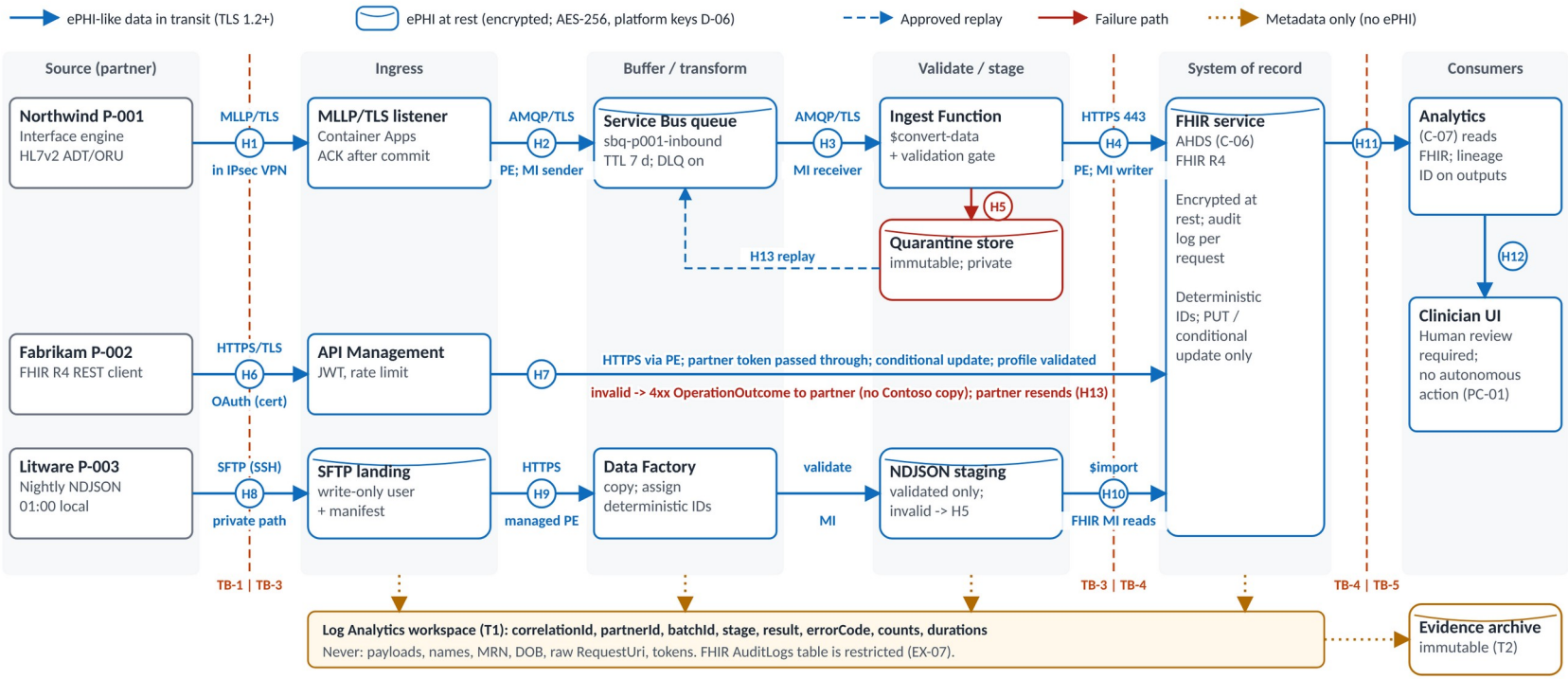


Figure 2. End-to-end ePHI data flow (M2), with hop IDs, protocols, storage points, the failure path to quarantine, approved replay and the metadata-only telemetry path. Vertical dashed lines are trust-boundary crossings.

Table 4. Per-hop register: classification, protocol, identity, authorization, protection, validation, audit event, failure path, retention and evidence owner.

Hop	Class	Protocol	Identity	Authorization	Transport / storage protection	Validation	Audit event	Failure path	Retention	Evidence owner
H1 Northwind engine → MLLP listener	ePHI-like HL7v2	MLLP over TLS 1.2 inside IPsec VPN	Listener server cert (KV); partner by VPN peer + source IP	NSG allows only Northwind subnet	TLS (A-01) + IPsec; no storage	MLLP framing, MSH present, size ≤1 MB	Ledger Received: msgIdHash, correlationId	NACK (AE); partner engine retries	None (transit)	Integration Eng
H2 Listener → Service Bus	ePHI-like	AMQP/TLS 1.2 via PE	uami-ingest-listener	Service Bus Data Sender on one queue	TLS; Premium, zone-redundant, encrypted at rest	partnerId stamp; MessageId duplicate detection	Ledger Enqueued	Enqueue fails → NACK; nothing ACKed is lost	TTL 7 days; removed on completion	Platform Eng
H3 Queue → ingest Function	ePHI-like	AMQP/TLS via PE	uami-ingest-worker	Service Bus Data Receiver on the queue	TLS; processed in memory, no disk writes	Peek-lock; ledger dedupe on msgIdHash	Ledger Dequeued, deliveryCount	Abandon + backoff; 5 deliveries → DLQ → H5	n/a	Integration Eng
H4 Function → FHIR ($convert-data, write)	ePHI-like HL7v2 → FHIR R4	HTTPS TLS 1.2 via PE	uami-ingest-worker	FHIR Data Converter + FHIR Data Writer	TLS; FHIR encrypted at rest (D-06)	Template version gate; profile, terminology, references	FHIR AuditLogs (caller object ID); ledger Persisted	5xx/429 retry 3x; unknown → read-before-retry; invalid → H5	System of record (partner agreement)	Integration Eng / Data Gov

Hop	Class	Protocol	Identity	Authorization	Transport / storage protection	Validation	Audit event	Failure path	Retention	Evidence owner
H5 Function or ADF → quarantine	ePHI-like (invalid item)	HTTPS via PE	uami-ingest-worker; ADF MI	Custom Quarantine Writer (no delete)	Encrypted; time-based immutability	failureCode and failureStage required	Ledger Quarantined (metadata only)	Write fails → item stays in queue/DLQ; SLO-06	30 days after resolution; manual disposal (D-05)	Integration Eng
H6 Fabrikam → API Management	ePHI-like FHIR R4	HTTPS TLS 1.2 over private path	Fabrikam app, certificate credential (EX-06)	validate-jwt: issuer, audience, client ID	TLS; no storage; body logging off	Method allow-list; 40 req/s limit	APIM gateway log (no body)	401/403 → SLO-05; 429 → partner backs off	None	Platform Eng
H7 API Management → FHIR	ePHI-like	HTTPS via PE	Fabrikam token passed through	FHIR Data Writer (Fabrikam SP)	TLS; encrypted at rest	US Core profile validation; conditional update	FHIR AuditLogs as Fabrikam	4xx OperationOutcome → partner fixes and resends	System of record	Integration Eng
H8 Litware → SFTP landing	ePHI-like NDJSON	SFTP (SSH) over private path (A-04)	Local user, SSH public key (EX-03)	Create + write on one container only	SSH; blob encrypted; public access off	Manifest present; file count and size match	StorageBlobLogs SFTP write	No manifest by 02:00 → P2 alert	Landing files 7 days after import	Platform Eng
H9 Landing → ADF → staging	ePHI-like	HTTPS via managed PE	ADF system MI; validation Function MI	Blob Data Reader (landing); Contributor (staging)	TLS; staging encrypted	Profile, terminology, references; ID assignment; SHA-256 per file	ADFPipelineRun / ActivityRun; ledger batch counts	Transient retry 3x; invalid lines → H5	Staging 7 days after reconcile	Integration Eng
H10 Staging → FHIR ($import)	ePHI-like	HTTPS; trusted-service access with MI	ADF MI starts job; FHIR system MI reads	FHIR Data Importer; Blob Contributor on staging (FHIR MI)	TLS; encrypted	Validated files only; incremental mode; batchId	FHIR AuditLogs (import); ledger Imported	Retry transient; partial → reconcile, replay failed lines	System of record	Integration Eng
H11 FHIR → analytics (C-07)	ePHI-like → derived	HTTPS via PE	uami-analytics	FHIR Data Reader	TLS; derived data encrypted	Reads pinned resource versions; lineage ID	FHIR AuditLogs (reads); App Insights metadata	Read fails → no output; stale-data flag	Regenerable; per D-05	Clinical Ops / Data Gov
H12 Analytics → clinician UI	ePHI-like decision support	HTTPS TLS 1.2	Named clinician (Entra ID, MFA)	App role by care team; Conditional Access	TLS; no local caching; 15-min idle logoff	Lineage ID + model version shown; clinician accepts or overrides	App audit: user, action, token (no values)	Unavailable → standard clinical workflow	Per clinical record policy	Clinical Ops
H13 Approved replay	ePHI-like	AMQP/HTTPS via PE	Logic App MI starts pl_replay	Approval record (ID, scope, expiry) + Ingest Operator role	TLS; encrypted	Count ≤ partner limit; idempotency; 1,000-item chunks	AutomationAudit_CL: approver, scope, counts	Stop on duplicate or mismatch; restore checkpoint	Approval record 6 years (D-05)	On-call Lead
T1/T2 Telemetry → workspace → archive	Metadata; AuditLogs ePHI-bearing (EX-07)	HTTPS via AMPLS	Diagnostic settings; DCR with MI	Table-level RBAC; AuditLogs SecOps only	TLS; archive immutable	Schema allow-list; KQL-10 leak scan	LAQueryLogs (who queried)	Freshness alert KQL-03 → RB-AUDIT-001	90 d interactive; evidence 6 y (D-05)	Security Operations

Table 4b. Where ePHI rests, and the retention decision for each store (D-05, proposed until OQ-05 closes).

Store	Contents	Encryption and access	Immutability	Retention	Disposal	Owner
Service Bus queue	HL7v2 messages in flight	AES-256 (platform); Entra RBAC only, SAS disabled	n/a	TTL 7 days; removed when processed	Normal message completion (not a disposal action)	Platform Eng
Quarantine container	Invalid items (only copy) + metadata	AES-256; Quarantine Writer has no delete; read via PIM	Time-based policy, unlocked until D-05 approval	30 days after resolution	**Manual, two-person** (AUT-11), legal-hold check first	Integration Eng / Data Gov
SFTP landing (p003)	Partner NDJSON + manifest (transient copy)	AES-256; partner write-only; ADF read	None	7 days after import	Lifecycle rule approved once under D-05; deletes only batches whose Reconcile record is balanced	Platform Eng
NDJSON staging	Validated NDJSON (transient copy)	AES-256; ADF write; FHIR MI read	None	7 days after reconcile	Same pre-approved lifecycle rule, post-reconcile only	Integration Eng
FHIR service	System of record (versioned)	AES-256; FHIR data roles; private only	Version history kept	Per partner agreement and record policy	Never by platform automation (no FHIR Data Contributor assigned)	Data Governance
Log Analytics audit tables	AuditLogs, gateway logs (EX-07), automation audit	Workspace encryption; table-level RBAC	n/a	90 d interactive; 6 y total	Retention expiry; purge only via AUT-11	Security Ops
Evidence archive	Daily evidence exports, approvals, reports	AES-256; read via PIM	Time-based 6 y; locked after D-05 approval; legal hold	6 years	Expiry after legal-hold check	Security Ops

3 Identity and Access Management

Principles. Eliminate secrets first; Key Vault holds only what cannot be eliminated. Each workload function gets one user-assigned managed identity, with roles at the narrowest scope (queue, container, vault object) and no Owner or Contributor. Humans get access through Entra ID groups only, with MFA enforced by Conditional Access; production roles are PIM-eligible, never standing, and no human has standing FHIR data access. Partners hold no Azure roles (Team table) and use the strongest method their interface supports.

Table 5. Workload identity and RBAC inventory (M1). Azure built-in roles unless marked custom.

Identity	Used by	Role → scope	Credential; notes
uami-ingest-listener	MLLP listener (Container Apps)	Azure Service Bus Data Sender → sbq-p001-inbound; Key Vault Secrets User → listener certificate object; Monitoring Metrics Publisher → DCR	MI; cannot receive from the queue
uami-ingest-worker	Ingest Functions	Service Bus Data Receiver → queue; FHIR Data Converter + FHIR Data Writer → FHIR; Quarantine Writer (custom, no delete) → quarantine; Key Vault Secrets User → HMAC key; Monitoring Metrics Publisher → DCR	MI; FHIR Data Contributor is assigned to no workload
ADF system MI	Data Factory (C-05)	Storage Blob Data Reader → landing/p003; Storage Blob Data Contributor → staging; FHIR Data Importer + Converter → FHIR; Quarantine Writer → quarantine	MI; client secret removed and revoked (REM-01)
FHIR service system MI	FHIR service (C-06)	AcrPull → template registry; Storage Blob Data Contributor → staging account (import)	MI
uami-analytics	Analytics (C-07)	FHIR Data Reader → FHIR service	MI; read-only
APIM system MI	API Management	Key Vault Secrets User → gateway certificate object	MI; partner token is passed through, APIM never calls FHIR as itself
Logic App system MI	Incident and approval flows (C-09)	Log Analytics Reader → workspace (not AuditLogs); Ingest Operator (custom: queue status, ADF trigger start/stop, createRun) → named resources; Policy remediation (custom) → integration RG	MI; no FHIR data role
Fabrikam app registration	Partner P-002	FHIR Data Writer → FHIR; APIM checks issuer, audience, client ID	Certificate; Contoso holds public key only (EX-06)
Litware local user	Partner P-003	Create + write → landing container p003 (no read, list, delete)	SSH public key; no password (EX-03)
SHIR nodes (2)	Northwind re-export	Registered to integration runtime shir-p001	Auth key in Key Vault (EX-05); virtual service account

Table 6. Human access model (MFA via Conditional Access for all; PIM activation needs justification and ticket ID).

Group (members)	Standing access	PIM-eligible (max duration)	Activation approval
Platform engineers (4)	Reader on platform RGs; Log Analytics Reader (no AuditLogs)	Contributor on integration RG (4 h); Ingest Operator (4 h)	Self; ticket ID
On-call Lead (1/shift)	As engineers; approver role in replay flow	Contributor on integration RG (4 h)	Self; ticket ID
Security Operations (3)	Security Reader; Log Analytics Reader incl. AuditLogs	Key Vault Administrator (2 h); FHIR Data Reader for investigation (2 h)	Second SecOps member
Privacy Officer (1)	Evidence archive reports (read)	None; does not operate production	n/a
Clinical Operations (2)	Clinician UI app roles; business dashboard	None	n/a
Break-glass (2 accounts)	Cloud-only; FIDO2 keys in separate safes	Used only if PIM or Entra ID fails	Any sign-in pages SecOps (KQL-11)

Automatic logoff: Conditional Access sign-in frequency of 4 h for admin portals; PIM activations ≤4 h; clinician UI logs off after 15 min idle. **Key Vault:** Azure RBAC permission model (no access policies), private endpoint, public access disabled, soft delete with purge protection, roles scoped to individual objects, and Event Grid near-expiry events at 30 days.

Table 7. Exception register (compensating controls, owner, quarterly review).

ID	Exception	Constraint	Compensating controls	Owner
EX-01	Logic App HTTP trigger reachable from Azure Monitor action groups	PC-02	Entra-authorized secure webhook; no SAS callback; inbound limited to ActionGroup service tag; metadata-only payload	Platform Security
EX-02	Teams approval connector uses a delegated connection (dedicated service account)	PC-03	Conditional Access on the account; no PHI in cards; responder checked against approver group; quarterly review	Identity & Security
EX-03	Litware SFTP local user uses an SSH key, not Entra ID	PC-03	Key-only; write-only on one container; private endpoint; StorageBlobLogs monitored; annual rotation	Platform Eng
EX-04	Site-to-site VPN pre-shared key	PC-03	32+ random characters; held only in gateway config; changed via PIM; annual rotation	Network Security
EX-05	Self-hosted IR authentication key	PC-03	Only in Key Vault; read under PIM at node registration; regenerated after any rebuild	Platform Eng
EX-06	Fabrikam service principal (not a managed identity)	PC-03 SP review	Certificate or federated credential; APIM client-ID check; rate limit; KQL-05; location-based workload CA if licensed	Identity & Security

ID	Exception	Constraint	Compensating controls	Owner
EX-07	FHIR AuditLogs RequestUri and APIM gateway Url can carry identifiers (conditional-update query strings)	PC-05	Table-level RBAC (SecOps only); never projected to dashboards or tickets; treated as ePHI-bearing evidence; ingestion-time transformation evaluated (REM-10)	Privacy Officer

4 HIPAA Technical Safeguards Mapping

Mapped to the Security Rule **as currently in force**: 45 CFR 164.312, plus the 164.308 and 164.316 standards that the technical controls depend on. The update proposed in January 2025 would remove the required/addressable distinction, but it was still not final at the time of writing (HHS target: July 2027), so it is not the baseline. Where this design already meets proposed items (MFA, encryption, asset inventory), that is forward compatibility, not a compliance claim. Addressable specifications are implemented where reasonable and appropriate, or an equivalent alternative is documented (164.306(d)(3)). R = required, A = addressable.

Table 8. HIPAA Security Rule mapping with evidence, residual gaps and compensating controls.

45 CFR reference	Implementation (controls)	Evidence	Residual gap	Compensating / remediation
164.312(a)(1) Access control	Private endpoints; RBAC at narrowest scope; no standing human FHIR data access (CTRL-001, 002, 004)	Role export; PE state; KQL-05	Fabrikam is a non-managed SP	EX-06 controls
(a)(2)(i) Unique user ID (R)	Named accounts; one MI per workload; partner token passed through so audit shows the real caller	Sign-in logs; CallerIdentityObjectId	SHIR used a shared Windows account	Virtual account (REM-06)
(a)(2)(ii) Emergency access (R)	Two break-glass accounts; RB-ACCESS-001 path; queue buffers data in an outage	Sign-in alert; test record	Not yet tested	Semiannual test (9.4)
(a)(2)(iii) Automatic logoff (A, implemented)	CA sign-in frequency 4 h; PIM ≤4 h; clinician UI 15-min idle logoff	CA policy export	None	n/a
(a)(2)(iv) Encryption/decryption (A, implemented)	Platform AES-256 at rest on every ePHI store (Table 4b, D-06); Key Vault for certificates	Encryption config; Defender for Cloud	No customer-managed keys	Accepted risk (D-06)
164.312(b) Audit controls (R)	FHIR AuditLogs, ADF runs, Activity Log, automation audit; DINE policy; 20-min freshness alert; canary; immutable archive	KQL-03 history; archive; Policy compliance	47-min gap (INC-2026-027); identifiers in RequestUri	REM-03; RB-AUDIT-001; EX-07
(c)(1) Integrity	Validation gate; deterministic IDs; 15-min reconciliation; quarantine; duplicate check	KQL-01, KQL-08	Partner data not signed	Private path, TLS, reconciliation
(c)(2) Authenticate ePHI (A, implemented)	SHA-256 per Litware file at landing, re-checked before import; FHIR meta.versionId history; immutable quarantine	Ledger hash match; FHIR history	No partner checksum	Request checksum in manifest
164.312(d) Person or entity authentication (R)	MFA for humans; MI tokens; Fabrikam certificate; Litware SSH key; Northwind IPsec peer + listener TLS	Sign-in logs; KQL-05	Northwind is network-level only	Source-IP limit; mutual TLS if supported (OQ-01)
164.312(e)(1) Transmission security	Private paths only; Policy deny on public access	PE, DNS, public-deny tests	EX-01 trigger endpoint	Entra-authorized trigger; service tag
(e)(2)(i) Integrity controls (A, implemented)	TLS 1.2+ (AEAD ciphers) on every hop; IPsec integrity; MLLP ACK	Minimum-TLS settings	None	n/a
(e)(2)(ii) Encryption (A, implemented)	TLS 1.2+ everywhere; IPsec (P-001); SSH (P-003)	TLS config export	MLLP TLS unconfirmed (A-01)	IPsec meets it until confirmed
164.308(a)(1)(ii)(D), (a)(6)(ii) Activity review; incident response (R)	Daily checks, dashboards, weekly anomaly review; RB-AUDIT-001, RB-INGEST-001, RB-ACCESS-001; Privacy Officer leads breach risk assessment	Daily-check log; incident timelines	None	n/a
164.308(a)(7) Contingency plan (R)	Zone-redundant queue; partner re-export; RTO 2 h tested quarterly	DR test report	Regional DR open (OQ-07)	Re-send from ledger checkpoint
164.316(b)(2)(i) Documentation retention (R)	Runbooks, approvals, risk decisions kept 6 years (D-05)	Archive inventory	Not approved (OQ-05)	Immutability unlocked until approval
164.308(b), 164.314(a) BA contracts	Microsoft BAA; partner BAAs	Contract register	Unconfirmed (A-07)	Go-live gate (OQ-04)

5 Monitoring Dashboard Specification

Two Azure Monitor workbooks read **saved KQL functions** that return metadata only. RequestUri, bodies, ADF Input/Output and raw identifiers are never projected; callers appear as object IDs and business keys as HMAC tokens. The query library and query records are in Appendix A.

5.1 Dashboard layout

Table 9. Dashboard tiles, metrics and targets.

Tile	Metric; visual and target	Query	Audience
Operational view (Integration Engineering, on-call). Refresh 5 min; default 24 h; filter by partner.			
O1	Accepted and reconciled rate per partner (SLO-01); line, 15-min bins, reference lines at 99.5% and 98%	KQL-01	On-call
O2	P95 end-to-end latency (SLO-02); line vs 120 s (P-001) and 90 s (P-002)	KQL-02	On-call
O3	Litware batch timeline: arrival, validate, import, reconcile vs 05:00	KQL-06b	On-call, Clinical Ops
O4	ADF failed runs (SLO-04) and top-10 failing activities (template queries 7, 8)	KQL-06	On-call
O5	Quarantine backlog and oldest age by partner and failureCode (SLO-06); red at 5,000 or 60 min	KQL-07	On-call
O6	Service Bus active and dead-letter counts, oldest message age; RPO guard at 10 min	Metrics	On-call
O7	Replays: approvals, items replayed, duplicate result (SLO-07, must be 0)	KQL-08	On-call Lead
O8	Throughput vs peak: msg/s per partner vs 120 msg/s and 40 req/s	KQL-01	Platform
Compliance and security view (Security Operations, Privacy Officer). Refresh 15 min; default 7 days.			
S1	Audit-log freshness per source (SLO-03); status grid, red above 20 min	KQL-03	SecOps
S2	Diagnostic-setting changes, resource moves, Policy compliance %	KQL-04	SecOps
S3	401/403 by caller vs 7-day baseline (SLO-05): attempts, ratio, IPs	KQL-05	SecOps
S4	PIM activations and role-assignment changes; timeline by group	KQL-11	SecOps
S5	Automation actions on ePHI systems with approval status; missing approvals must be 0	KQL-09	SecOps, Privacy
S6	Telemetry payload-leak scan; must be 0	KQL-10	Privacy Officer
S7	Evidence export status; Key Vault certificates <30 days to expiry	Metrics	SecOps
S8	Break-glass sign-ins; must be 0 outside tests	KQL-11	SecOps

5.2 Alert thresholds and escalation

Table 10. Alert thresholds, evaluation and routing. Thresholds come from the SLO sheet unless marked LD (learner decision).

ID	Signal (query)	Threshold; evaluation	Sev	Route	Runbook
A1	Ingestion success (KQL-01)	<99.5% per 15-min window → P2; <98% → P1; every 5 min	P1/P2	Page / ticket	RB-INGEST-001
A2	P95 latency (KQL-02)	>120 s (P-001) or >90 s (P-002) for 15 min; tune after 2 weeks	P2	Ticket	RB-INGEST-001
A3	Audit freshness (KQL-03)	>20 min since last event on any source; every 15 min	P1	SecOps + engineer	RB-AUDIT-001
A4	Diagnostic setting deleted or resource moved (KQL-04)	Any successful event on in-scope resources (LD)	P1	SecOps	RB-AUDIT-001
A5	ADF failures (KQL-06)	≥3 failed runs in 30 min → P1; 1–2 → P2; cancelled excluded	P1/P2	Page / ticket	RB-INGEST-001
A6	Denied FHIR requests (KQL-05)	≥20 events and ≥3x baseline per caller in 1 h	P2	SecOps queue	RB-ACCESS-001
A7	Quarantine backlog (KQL-07)	≥5,000 or oldest ≥60 min → P2; both, or ≥10,000 → P1 (LD)	P1/P2	Page / ticket	RB-INGEST-001
A8	Replay duplicates (KQL-08)	>0 duplicates after any replay	P1	On-call Lead	RB-INGEST-001
A9	Litware batch (KQL-06b)	No manifest by 02:00 → P2; not reconciled by 04:30 → P1 (LD)	P2/P1	Ticket / page	RB-INGEST-001
A10	Payload leak or missing approval (KQL-10, 09)	≥1 hit	P1	SecOps + Privacy	RB-ACCESS-001
A11	Queue age (Service Bus metric)	Oldest message >10 min → P2; >15 min (RPO) → P1 (LD)	P2/P1	Ticket / page	RB-INGEST-001

Escalation. P1: the primary engineer is paged and acknowledges within 10 min; with no acknowledgement at 10 min the On-call Lead is paged; containment target is 30 min (PC-08). Security P1s (A3, A4, A10) also page Security Operations, who bring in the Privacy Officer for any possible impermissible disclosure, and Clinical Ops when partner workflow impact is material. P2: ITSM ticket and team channel, triaged within the shift, no page. **Hygiene for four engineers:** only eight rules can page; alerts are stateful and auto-resolve; processing rules group per partner per 30 min and suppress approved maintenance; thresholds are reviewed after two weeks of baseline and after every incident.

5.3 Key KQL snippet (full library in Appendix A)

KQL-03 replaces template query 4. The template multiplied `datetime_diff('minute', now(), LastEvent)` by -1, which made the value negative, so the freshness alert could never fire. The fix also flags a source that sent nothing at all.

```
// KQL-03  SLO-03 audit-log freshness (alert: any row with Breach == true; every 15 min)
let Threshold = 20;
let Expected = datatable(Source:string)["FHIR", "ADFRun", "ADFActivity", "Ledger"];
let Last = union
  (MicrosoftHealthcareApisAuditLogs | where TimeGenerated > ago(6h) | summarize LastEvent = max(TimeGenerated) | extend Source = "FHIR"),
  (ADFPipelineRun   | where TimeGenerated > ago(6h) | summarize LastEvent = max(TimeGenerated) | extend Source = "ADFRun"),
  (ADFActivityRun   | where TimeGenerated > ago(6h) | summarize LastEvent = max(TimeGenerated) | extend Source = "ADFActivity"),
  (IngestLedger_CL  | where TimeGenerated > ago(6h) | summarize LastEvent = max(TimeGenerated) | extend Source = "Ledger");
Expected
| join kind=leftouter Last on Source
| extend MinutesSinceLastEvent = iif(isnull(LastEvent), long(360), datetime_diff('minute', now(), LastEvent))
```

```
| extend Breach = MinutesSinceLastEvent > Threshold
| project Source, LastEvent, MinutesSinceLastEvent, Breach
```

6 Data Integration Pipeline Design

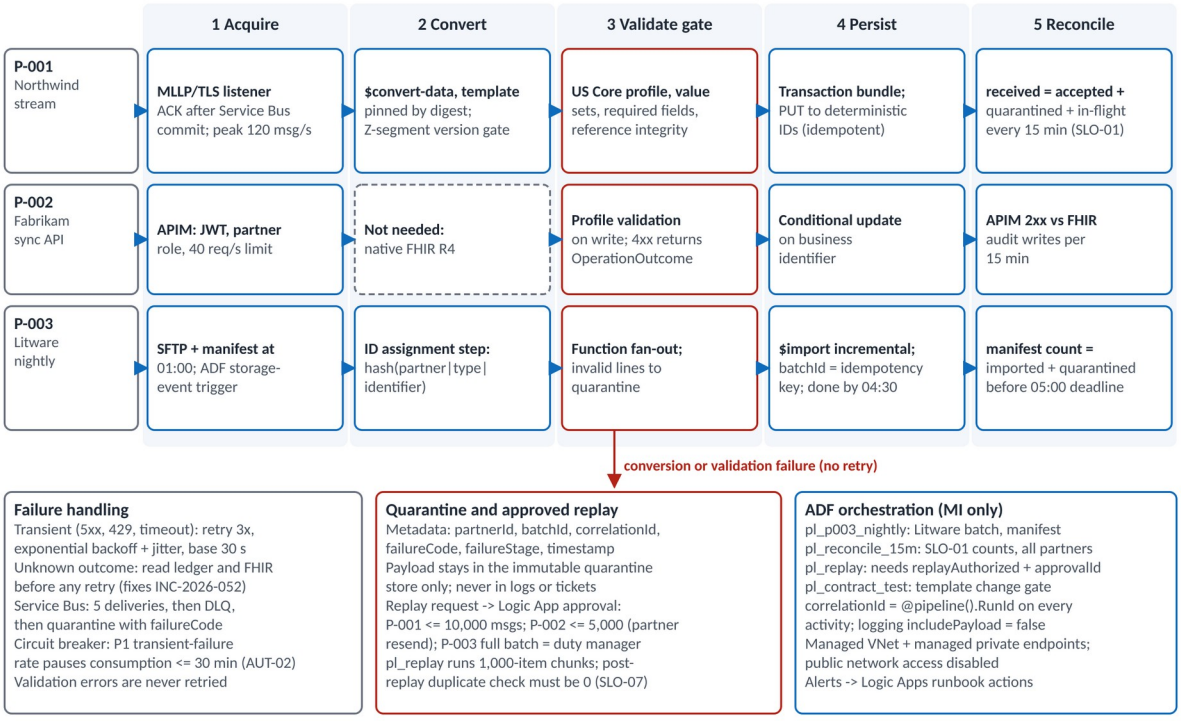


Figure 3. FHIR ingestion and ADF orchestration (M4). Five stages per partner, the validation gate (red), failure handling, quarantine and approved replay.

Correlation (REM-04). A correlationId is minted at first contact (listener, API Management or manifest) and carried in Service Bus properties, the `X-Correlation-ID` header and ADF parameters; the ledger maps each ADF `RunId` to it. One ID traces a record from partner to FHIR audit event without logging content.

6.1 Validation gate (CTRL-008)

A record is persisted only if it passes six checks; failures are quarantined, never retried. (1) **Structure**: valid FHIR R4 JSON within size limits. (2) **Profile**: the US Core version pinned per partner (Northwind output included). (3) **Terminology**: required bindings, for example LOINC on Observation.code. (4) **Required fields**: identifier, subject, effective time. (5) **References** resolve in the bundle or to an existing resource. (6) **Identity**: the ID equals hash(partnerId|resourceType|identifier), so no partner can overwrite another partner's resource.

Table 11. Error taxonomy, retry policy and routing.

failureCode	Stage	Class	Retry policy	Route
TRANSIENT_5XX, THROTTLED_429	Persist, import	Transient	3 attempts, exponential backoff with jitter (30, 60, 120 s ±20%); honour Retry-After	Then DLQ → quarantine; counts toward circuit breaker (AUT-02)
TIMEOUT_UNKNOWN	Persist	Unknown outcome	Read before retry: ledger, then GET by deterministic ID	Found → mark Persisted; not found → normal retry
CONNECTIVITY	Acquire	Transient	Partner resends (NACK) or re-uploads	A11, A9
UNKNOWN_TEMPLATE_VERSION, CONVERSION_FAILED	Convert	Non-transient	None	Quarantine; partner contact; contract test reproduces
PROFILE_INVALID, TERMINOLOGY_INVALID, REQUIRED_FIELD_MISSING	Validate	Non-transient	None	Quarantine; counted as ValidationRejected and reported apart from SLO-01
REFERENCE_UNRESOLVED	Validate	Possibly ordering	One delayed re-validation after 10 min	Then quarantine
RECONCILIATION_MISMATCH, DUPLICATE_SUSPECTED	Reconcile	Integrity	None	Create incident and stop (template failureAction); A8 P1

6.2 Replay, template change and recovery

Replay (D-03, D-04). (1) After the fix, an engineer selects quarantined items by partner, failureCode and time range, with count, reason and ticket. (2) Flow F3 checks the partner limit (P-001 10,000; P-002 5,000 resent by the partner; P-003 full batch needs the duty manager), that requester ≠ approver, that no FHIR P1 is open and that the template digest is current. (3) A peer engineer approves within the limit, the On-call Lead for multi-batch or full-batch; approval expires in 2 h. (4) `pl_replay` runs with `replayAuthorized=true` and the approvalId in 1,000-item chunks, reading before each write

and checkpointing each chunk. (5) Closure needs KQL-08 = 0 and attempted = succeeded + re-quarantined; otherwise it stops, restores the checkpoint and raises a P1.

Template change (D-02). Partner notice ≥10 business days with synthetic samples (OQ-06); CI contract test on old and new versions (converts, validates, identical IDs across two runs, expected counts); digest recorded; version-gate mapping released with approval; old digest kept for one-line rollback; A1 and A7 watched by failureCode for 24 h.

Capacity, latency, recovery (A-08). P-001 peaks at 120 msg/s; Functions Premium scales to a capped instance count and backs off on FHIR 429s; load test LT-01 runs at 180 msg/s. P-001 budget: enqueue <1 s + queue wait ≤30 s + convert/validate ≤5 s + write ≤5 s ≈ 45 s p95 vs 120 s. P-002 is synchronous, about 5 s vs 90 s. P-003: arrival 01:00, validation about 30 min, reconciled by 04:30. **Recovery:** zone-redundant queue with ACK-after-commit keeps acknowledged data through a zonal failure; the 10-min queue-age alert protects the 15-min RPO; after a regional failure partners re-send from the last ledger checkpoint (OQ-07); analytics output is regenerated (PC-09); RTO 2 h is tested quarterly.

7 Automation Strategy

Actions are scored with the Automation Decision Template: **Base = Sensitivity × Impact + Reversibility × Blast radius + (6 − Confidence) × 2**; 0–24 automatic, 25–39 approval-gated, 40+ manual. Mandatory gates (access change, delete, retention, clinical impact) override the score, and a final decision may be stricter. Every automation runs as a scoped managed identity with timeout, retry limit, pre- and post-validation and an audit record.

Table 12. Automation decision matrix (D-04). Scores: S, I, R, B, C = sensitivity, impact, reversibility difficulty, blast radius, detection confidence (1–5).

ID	Trigger → action	S I R B C	Base	Gate	Decision	Identity; approver; expiry	Rollback
AUT-01	Audit freshness breach or diagnostic setting deleted → create P1 incident, snapshot config, start Policy remediation	2 2 1 2 5	8	None	**Automatic**	Logic App MI; n/a	Remove re-created setting (rarely needed)
AUT-02	P1 SLO-01 breach with transient failures (P-001, P-003) → pause consumption (queue ReceiveDisabled or stop trigger) for ≤30 min	3 3 2 3 4	19	None	**Automatic**, auto-expires	Ingest Operator; extension needs AUT-07	Queue Active / restart trigger from checkpoint
AUT-03	Conversion or validation failure → quarantine item	4 3 2 1 5	16	None	**Automatic**	uami-ingest-worker; n/a	Replay after fix (AUT-05)
AUT-04	Queue backlog → scale workers within cap	3 2 1 2 5	10	None	**Automatic**	Platform scale controller	Automatic scale-in
AUT-05	Replay ≤ partner limit (10,000 P-001; 5,000 P-002 resend) → run pl_replay	4 4 3 3 4	29	None	**Approval-gated**	Peer engineer (not requester); 2 h; >1 batch: On-call Lead	Stop, restore checkpoint, re-quarantine
AUT-06	Litware full-batch replay → re-run pl_p003_nightly	4 4 3 3 4	29	None	**Approval-gated**	Duty manager (A-02); until 05:00	Stop; reconcile; partner re-export
AUT-07	Pause beyond 30 min, or pause Fabrikam (APIM 503 + Retry-After)	3 4 2 3 4	22	None	**Approval-gated** (stricter than score: partner-visible)	On-call Lead; 4 h	Resume from checkpoint; partner notified
AUT-08	Workload-identity compromise indicator (KQL-05 + abnormal reads) → disable Fabrikam SP or remove its FHIR role	5 4 2 3 3	32	Access	**Approval-gated**	Security Operations (emergency identity containment); incident	Re-enable on SecOps approval; rotate cert
AUT-09	Human privileged account compromise → revoke roles and sessions	5 5 3 4 3	43	Access	**Manual**	SecOps via PIM; incident commander	Restore only on approval
AUT-10	Exfiltration indicator → isolate FHIR private endpoint	5 5 4 5 3	51	Clinical	**Manual**	SecOps commander + Clinical Ops	Re-apply approved network config
AUT-11	Quarantine disposal, purge, retention change	5 5 5 4 4	49	Delete, retention	**Manual**, two-person	Privacy Officer + Data Governance (On-call Lead cannot approve alone)	Irreversible; check legal hold first
AUT-12	Any action that changes clinical data or decisions	n/a	n/a	Clinical	**Prohibited** (PC-01)	n/a	n/a

7.1 Automation flows (Logic Apps Standard and Functions)

F1 Alert to incident (`la-incident-orchestrator`): secure-webhook trigger with the common alert schema (EX-01) → allow-list the rule ID → de-duplicate per alert and partner for 30 min → create ITSM incident with severity and runbook ID → attach a counts-only KQL snapshot → run the automatic action or request approval per Table 12.

F2 Circuit breaker (`fn-circuit-breaker`, durable): checks no maintenance window, transient failure class, not already paused → sets the queue to ReceiveDisabled or stops the ADF trigger → re-evaluates at 30 min → resumes if canary and error rate are healthy, else asks the On-call Lead to extend (AUT-07). The listener keeps accepting, so nothing is refused or lost.

F3 Replay gate (`la-replay-gate`) runs replay steps 2–5 (Section 6.2); ADF enforces it again, because `pl_replay` starts with an If Condition that fails unless `replayAuthorized` is true, an approvalId exists and the count is within the limit (Appendix E). **F4 Daily evidence** (`la-evidence-daily`) exports results to the immutable archive (Section 8.3).

Every action touching an ePHI-bearing system is logged. Each flow writes an `AutomationAudit_CL` record at start and end (automationId, correlationId, incident and alert IDs, action, target, partnerId, item count, approvalId, approver and executor object IDs, expiry, pre/post checks, result, rollback reference; schema in Appendix A). The data-plane effect also appears in FHIR AuditLogs or ADF logs under the same managed identity, joined by correlationId. No payloads or identifiers; KQL-09 alerts on any gated action without an approvalId.

8 Compliance Remediation Runbook

8.1 RB-AUDIT-001: Restore FHIR and pipeline audit-log continuity

Field	Entry	Field	Entry
Version / reviewed	v1.0 / 2026-10-11	**Owner / approver**	Security Operations / SecOps lead
Severity	P1 (SLO-03)	**Related alerts**	A3 (KQL-03), A4 (KQL-04)
Controls	CTRL-005, CTRL-011; 164.312(b); 164.308(a)(1)(ii)(D)	**Targets**	FHIR service C-06, ADF C-05, workspace C-08, evidence archive
Purpose / scope	Restore audit-log flow within 30 min and bound any evidence gap (INC-2026-027). Not partner logs or data backlog (RB-INGEST-001).	**Entry; false positives**	A3 or A4 fires, confirmed by running KQL-03. Approved maintenance is suppressed; an Azure Monitor incident is still an evidence gap (do steps 6–7).
No approval needed	Policy remediation, re-creating the approved diagnostic setting, re-running evidence export.	**Approval needed**	Changing destinations, retention or policy assignments (SecOps lead + Privacy). Break-glass only if PIM is unavailable.
Prerequisites	Monitoring Contributor on target via PIM (2 h); Log Analytics Reader including AuditLogs; Azure CLI.	**PHI-safe evidence**	No screenshots of AuditLogs rows; export counts and timestamps only; never RequestUri.

Table 13. RB-AUDIT-001 procedure. Capture alert ID, KQL-03/04 output, current diagnostic-setting JSON and incident ID before step 4.

#	Command / portal path	Expected output	Decision / stop condition	Evidence to retain
1	Acknowledge page; open P1 incident; start timeline	Incident ID within 10 min	No ack at 10 min → On-call Lead paged	Incident ID, timestamps
2	Run saved functions `fn_AuditFreshness` (KQL-03) and `fn_DiagChanges` (KQL-04)	Gap per source; delete or move event and caller	No config change + Azure service incident → go to step 6	Query output (CSV, counts only)
3	`az monitor diagnostic-settings list --resource <FHIR_RESOURCE_ID>`	`diag-fhir-audit` with AuditLogs → workspace + archive	Missing or changed → step 4	Setting JSON before change
4	`az policy remediation create --name rem-diag-fhir --policy-assignment <ASSIGNMENT_ID> --resource-group <RG>`	Remediation Succeeded; setting re-created	Fails → create setting from Appendix C template	Remediation ID; setting JSON after
5	Re-run KQL-03; confirm FHIR canary read	New AuditLogs events within 20 min	Still none at 30 min → Microsoft support + CISO delegate	Query output
6	Bound the gap: first and last event either side; compare ledger and Activity Log for that window	Gap start/end; operations during gap	ePHI access in gap cannot be reconstructed → Privacy Officer (breach risk assessment)	Gap report
7	Root cause: who moved or edited the resource; was DINE assigned at that scope?	Problem record	Missing guardrail → change request	Problem ticket

Validation: freshness <20 min for two evaluations; archive export resumed; Policy compliant; one canary correlationId traced end to end. **Rollback:** restoration is additive; if a wrong destination was added, delete only that setting, never the archive. **Communications:** SecOps lead at P1; Privacy Officer if step 6 escalates; Clinical Ops only if ingestion is affected; updates every 30 min. **Closure:** evidence to archive (owner SecOps, D-05); review within 5 business days; update this runbook if a step failed.

8.2 Remediation plan for known gaps

Table 14. Remediation items. "Go-live" items block production onboarding.

ID	Gap (source)	Remediation	Owner	Due	Closure evidence
REM-01	ADF client secret (C-05, INC-2026-014)	Switch linked service to MI; revoke secret; repo secret scanning with push protection	Identity & Security	Go-live	Role record, revocation ticket, scan report
REM-02	Public exposure: ADF, FHIR, workspace, Logic App (C-05, C-06, C-08, C-09)	Private endpoints, publicNetworkAccess Disabled, AMPLS (D-07), Logic Apps Standard with EX-01 controls, Policy deny	Platform Eng	Go-live	Public-deny test results
REM-03	Audit-log drift (C-06, INC-2026-027)	DINE policy, delete alert, freshness alert, canary, RB-AUDIT-001 tabletop	Security Ops	Go-live	Policy compliance; tabletop record
REM-04	No unified correlation ID (C-02)	correlationId at first contact, propagated (Section 6)	Integration Eng	30 days	End-to-end trace test
REM-05	Template drift (INC-2026-041)	D-02 controls; partner change agreement (OQ-06)	Integration Eng + P-001	Go-live	Contract-test report
REM-06	Single-node SHIR; shared Windows account (C-03)	Two nodes; virtual service account; key in Key Vault	Platform Eng	30 days	Node status; failover test
REM-07	No replay gate (C-09); duplicates (INC-2026-052)	F3 flow, ADF gate, D-03; replay test at 10,000 items	Integration Eng / On-call Lead	Go-live	Replay report; KQL-08 = 0

ID	Gap (source)	Remediation	Owner	Due	Closure evidence
REM-08	Retention not approved (C-04); owner unclear (C-08)	Approve D-05; owners: SecOps (logs), Data Governance (data)	Privacy + Security + Legal	30 days	Signed retention decision
REM-09	No output lineage ID (C-07)	Lineage ID on every analytics output	Clinical Ops / Data Gov	90 days	Sample output trace
REM-10	Telemetry privacy baseline (PC-05)	Allow-list schema; KQL-10 scan; restrict AuditLogs; evaluate RequestUri transformation (EX-07)	Privacy Officer	Go-live	Scan = 0; access review

8.3 Audit evidence collection (RB-EVID-001)

Flow F4 runs daily at 06:00 ET and writes privacy-safe query results to `evidence/{yyyy}/{mm}/{dd}/` in the immutable archive with a SHA-256 manifest. **Daily:** freshness, Policy compliance, approvals (KQL-09), leak scan (KQL-10). **Monthly:** role and PIM export. **Per event:** replay, reconciliation and contract-test reports, template digests. **Quarterly:** access review, DR and failure-injection tests. **Semiannual:** tabletop, break-glass test. Each quarter the Privacy Officer samples one item per category for retrievability, completeness and absence of PHI.

9 Operational Procedures

9.1 RB-INGEST-001: Ingestion SLO breach, backlog or replay (P1/P2)

Authorization boundary: engineers may quarantine, pause ≤30 min and approve a peer's in-limit replay; the On-call Lead approves longer pauses and multi- or full-batch replays; nobody deletes data here.

#	Action	Expected result / stop condition
1	Acknowledge within 10 min; open incident with partner, alert ID and correlation IDs (never payloads).	Incident open; timeline started.
2	Classify with KQL-01, KQL-06 and KQL-07 by failureCode: transient, validation/conversion, or connectivity.	One class identified; mixed classes → handle transient first.
3	Transient: confirm circuit breaker state (AUT-02) and FHIR health and throttling. Connectivity: VPN, private DNS, SHIR nodes, partner contact. Validation: check the version gate and partner notices; deploy templates only through D-02 (no hotfix in production).	Cause isolated. Not recovering by 30 min → On-call Lead approves extended pause (AUT-07).
4	Contain within 30 min: data stays buffered in the queue or at the partner and nothing is discarded. Tell Clinical Ops if partner workflow impact passes 30 min.	Containment time recorded.
5	Recover and close: resume; replay quarantined items via F3 within limit; SLO met for two windows; review every P1.	KQL-08 = 0; reconciliation balanced; evidence archived.

9.2 RB-ACCESS-001: Denied-request spike, payload leak or credential compromise

(1) SecOps triages KQL-05: caller, operations, IPs, recent changes such as a certificate rotation. (2) Workload identity: approve and disable the service principal or its FHIR role (AUT-08); human account: revoke roles and sessions through PIM (AUT-09). (3) The caller's reads in the restricted AuditLogs go to the Privacy Officer for the breach risk assessment and notification decision. (4) Payload leak (KQL-10): restrict table access at once, fix the logging code, purge only via the two-person procedure (AUT-11). (5) Restore access only with SecOps approval and new credentials.

9.3 Daily checks (start of each 12-hour shift)

Check	Pass criterion	If failed
Litware batch reconciled (KQL-06b); SLO-01 over last 12 h (KQL-01)	Before 05:00 ET; every window ≥99.5%	RB-INGEST-001; Clinical Ops; problem record
Quarantine backlog and failure codes (KQL-07)	<5,000; oldest <60 min; no new codes	New code → partner contact (possible change)
Audit freshness, diagnostic changes (KQL-03/04); Policy compliance	All <20 min; 0 unapproved changes; 100% compliant	RB-AUDIT-001; remediate
Service Bus DLQ and queue age; SHIR nodes	DLQ 0; oldest <10 min; 2/2 nodes online	RB-INGEST-001; node repair
Automation approvals (KQL-09) and open circuit breakers	0 missing approvals; no expired pauses	SecOps P1 (control failure)
Leak scan (KQL-10); break-glass (KQL-11); certificates; evidence export (F4)	0; 0; >30 days; succeeded	RB-ACCESS-001; rotation; re-run F4

9.4 On-call handoff (each shift change, ~15 min, in ITSM) and periodic operations

Both engineers sign the handoff record: open incidents and severity; active pauses and expiry times; approvals in flight (approvalId, expiry); running replays (chunk progress, KQL-08); quarantine backlog and top failure codes per partner; pending partner communications; active suppressions; PIM activations still open (expected none); risks for the next shift (tonight's Litware batch, certificate expiry, changes). **No PHI in handoff notes**: IDs, counts and tokens only.

Weekly: alert-noise review. **Monthly:** role export, schema review, failure-code trends with partners. **Quarterly:** access review; DR test (RTO 2 h, RPO 15 min) plus regional tabletop (OQ-07); replay, failure-injection and SHIR failover tests; automation score review. **Semiannual:** break-glass test; RB-AUDIT-001 and RB-ACCESS-001 tabletops. **Annual:** retention review; SSH and VPN key rotation.

Appendix: Config Snippets and Supporting Detail

Appendix pages are numbered separately and fall outside the 10–14-page body. All values are synthetic or placeholders in the `<REPLACE_WITH_...>` convention. No secrets, tenant IDs or production endpoints appear.

A. KQL query library and query records

KQL-03 appears in Section 5.3. Template queries 1, 2, 5, 7, 8 and 9 are used unchanged as dashboard tiles. KQL-03 replaces template query 4 (sign error fixed), and KQL-06 replaces template query 10 (de-duplicated by RunId).

```
// KQL-01  SLO-01 accepted and reconciled rate per partner (rows written by pl_reconcile_15m after a 5-min settle; alert A1)
IngestLedger_CL
| where TimeGenerated > ago(24h) and Stage == "Reconcile"
| extend Eligible = Received - ValidationRejected          // validation rejects reported separately (PC-07)
| extend SuccessRate = iif(Eligible <= 0, 1.0, todouble(Accepted) / todouble(Eligible))
| extend Severity = case(SuccessRate < 0.98, "P1", SuccessRate < 0.995, "P2", "OK")
| project WindowStart, PartnerId, Received, Accepted, ValidationRejected, InFlight, SuccessRate, Severity
```

```
// KQL-02  SLO-02 P95 end-to-end latency vs partner target (alert A2)
let Targets = datatable(PartnerId:string, TargetSeconds:real)["P-001", 120.0, "P-002", 90.0];
let P001 = IngestLedger_CL
    | where TimeGenerated > ago(24h) and PartnerId == "P-001" and Stage == "Persisted"
    | project TimeGenerated, PartnerId, Seconds = todouble(EndToEndSeconds);
let P002 = ApiManagementGatewayLogs          // TotalTime in ms; Url is never projected (EX-07)
    | where TimeGenerated > ago(24h) and ApiId == "fhir-p002" and ResponseCode between (200 .. 299)
    | project TimeGenerated, PartnerId = "P-002", Seconds = todouble(TotalTime) / 1000.0;
union P001, P002
| summarize P95Seconds = percentile(Seconds, 95), Requests = count() by PartnerId, bin(TimeGenerated, 15m)
| join kind=inner Targets on PartnerId
| extend Breach = P95Seconds > TargetSeconds
| project TimeGenerated, PartnerId, P95Seconds, TargetSeconds, Requests, Breach
```

```
// KQL-04  Diagnostic-setting change or resource move on in-scope resources (alert A4, INC-2026-027)
AzureActivity
| where TimeGenerated > ago(1h)
| where OperationNameValue in~ ("MICROSOFT.INSIGHTS/DIAGNOSTICSETTINGS/DELETE",
                                "MICROSOFT.INSIGHTS/DIAGNOSTICSETTINGS/WRITE",
                                "MICROSOFT.RESOURCES/SUBSCRIPTIONS/RESOURCEGROUPS/MOVERESOURCES/ACTION")
| where ActivityStatusValue in~ ("Success", "Succeeded")
| project TimeGenerated, OperationNameValue, Caller, ResourceGroup, _ResourceId, CorrelationId
```

```
// KQL-05  SLO-05 denied FHIR requests per caller vs 7-day baseline (alert A6)
let BaselineDays = 7d;
let CurrentWindow = 1h;
let Denied = MicrosoftHealthcareApisAuditLogs
    | where StatusCode in (401, 403)
    | extend Caller = iif(isempty(CallerIdentityObjectId), strcat("unauthenticated:", CallerIPAddress), CallerIdentityObjectId);
let Baseline = Denied
    | where TimeGenerated between (ago(BaselineDays + CurrentWindow) .. ago(CurrentWindow))
    | summarize BaselineHourly = todouble(count()) / (BaselineDays / 1h) by Caller;
Denied
| where TimeGenerated >= ago(CurrentWindow)
| summarize Attempts = count(), DistinctIPs = dcount(CallerIPAddress), Operations = make_set(OperationName, 10) by Caller
| join kind=leftouter Baseline on Caller
| extend BaselineHourly = coalesce(BaselineHourly, 0.0)
| extend Ratio = Attempts / iif(BaselineHourly < 1.0, 1.0, BaselineHourly)
| where Attempts >= 20 and Ratio >= 3.0
| project Caller, Attempts, BaselineHourly, Ratio, DistinctIPs, Operations
```

```
// KQL-06  SLO-04 ADF failed runs in 30 min, de-duplicated by RunId; cancelled runs excluded (alert A5)
ADFPipelineRun
| where TimeGenerated > ago(30m) and Status == "Failed"
| summarize arg_max(TimeGenerated, PipelineName, FailureType) by RunId
| summarize Failures = count(), Pipelines = make_set(PipelineName, 10), LatestFailure = max(TimeGenerated)
| where Failures > 0
| extend Severity = iif(Failures >= 3, "P1", "P2"), RunbookId = "RB-INGEST-001"

// KQL-06b  Litware nightly batch at risk (alert A9; A-09 local time = America/New_York)
```

```
let LocalNow = datetime_utc_to_local(now(), "America/New_York");
let LocalDay = startofday(LocalNow);
IngestLedger_CL
| where TimeGenerated > ago(12h) and PartnerId == "P-003"
| extend LocalTime = datetime_utc_to_local(TimeGenerated, "America/New_York")
| where LocalTime >= LocalDay
| summarize ManifestAt = minif(LocalTime, Stage == "Received"), ReconciledAt = minif(LocalTime, Stage == "Reconcile")
| extend Severity = case(isnull(ReconciledAt) and LocalNow >= LocalDay + 4h + 30m, "P1",
                         isnull(ManifestAt) and LocalNow >= LocalDay + 2h, "P2", "OK")
```

```
// KQL-07  SLO-06 quarantine backlog and oldest item per partner (alert A7)
IngestLedger_CL
| where TimeGenerated > ago(14d) and Stage in ("Quarantined", "QuarantineResolved")
| summarize arg_max(TimeGenerated, Stage, FailureCode) by PartnerId, CorrelationId
| where Stage == "Quarantined"
| summarize Backlog = count(), OldestMinutes = datetime_diff('minute', now(), min(TimeGenerated)),
            TopCodes = make_set(FailureCode, 5) by PartnerId
| extend Severity = case(Backlog >= 10000 or (Backlog >= 5000 and OldestMinutes >= 60), "P1",
                         Backlog >= 5000 or OldestMinutes >= 60, "P2", "OK")
```

```
// KQL-08  SLO-07 duplicate resources after a replay: pass = no rows (alert A8)
let ReplayIdParam = "<REPLAY_ID>";
let Touched = IngestLedger_CL
    | where TimeGenerated > ago(2d) and ReplayId == ReplayIdParam and Stage == "Persisted"
    | distinct PartnerId, ResourceType, BusinessKeyToken;
IngestLedger_CL
| where TimeGenerated > ago(90d) and Stage == "Persisted"
| join kind=inner Touched on PartnerId, ResourceType, BusinessKeyToken
| summarize DistinctResources = dcount(ResourceIdToken) by PartnerId, ResourceType, BusinessKeyToken
| where DistinctResources > 1
| summarize DuplicateKeys = count() by PartnerId, ResourceType
// Backed by a FHIR-side identifier count (POST _search, _summary=count) on a 1% sample of keys.
```

```
// KQL-09  Automation actions on ePHI-bearing systems; any missing approval is a P1 control failure (A10)
AutomationAudit_CL
| where TimeGenerated > ago(24h) and TouchesEphiSystem == true
| extend MissingApproval = ApprovalRequired == true and isempty(ApprovalId)
| summarize Actions = count(), Failed = countif(Result != "Succeeded"), MissingApprovals = countif(MissingApproval)
    by AutomationId, Action, PartnerId
| order by MissingApprovals desc, Actions desc
```

```
// KQL-10  Payload-leak scan of telemetry text fields; report table and counts only, never the text (A10)
union isfuzzy=true
    (AppTraces       | where TimeGenerated > ago(1d) | project TimeGenerated, SourceTable = "AppTraces", Text = Message),
    (AppExceptions   | where TimeGenerated > ago(1d) | project TimeGenerated, SourceTable = "AppExceptions", Text = OuterMessage),
    (IngestLedger_CL | where TimeGenerated > ago(1d) | project TimeGenerated, SourceTable = "IngestLedger_CL", Text = FailureDetail)
| where Text matches regex @'(^|[\r\n])(MSH|PID|PV1|OBX)\|'     // HL7v2 segment
     or Text matches regex @'"resourceType"\s*:'               // FHIR JSON
     or Text matches regex @'\b\d{3}-\d{2}-\d{4}\b'              // SSN-like
     or Text matches regex @'(?i)bearer\s+[a-z0-9._-]{20,}'     // access token
| summarize Hits = count(), FirstSeen = min(TimeGenerated) by SourceTable
```

```
// KQL-11  Break-glass sign-ins and PIM activations (S4, S8)
SigninLogs
| where TimeGenerated > ago(24h) and UserPrincipalName in~ ("<BREAKGLASS_UPN_1>", "<BREAKGLASS_UPN_2>")
| project TimeGenerated, UserPrincipalName, ResultType, AppDisplayName, ConditionalAccessStatus

AuditLogs
| where TimeGenerated > ago(7d) and Category == "RoleManagement" and OperationName has "PIM activation"
| project TimeGenerated, OperationName, Identity, Result
```

Table A1. Query records (template "learner query record" fields, condensed).

Query	Table mode	PHI exposure review	Threshold basis	Severity; eval	Validation; limitation
KQL-01	Custom DCR (A-06)	Counts only	SLO-01	P1/P2; 5 min	Injected failures; needs settle delay

Query	Table mode	PHI exposure review	Threshold basis	Severity; eval	Validation; limitation
KQL-02	Custom + ApiManagementGatewayLogs	Url never projected	SLO-02 partner targets	P2; 15 min	Synthetic timing; tune after 2 weeks
KQL-03	Resource-specific (A-05)	Timestamps only	SLO-03 (15 min delay + 5)	P1; 15 min	Disable a test setting; quiet periods covered by canary
KQL-04	AzureActivity	Caller UPN (operational)	INC-2026-027	P1; 5 min	Delete test setting in dev
KQL-05	Resource-specific	Object ID, IP; no RequestUri	SLO-05 baseline	P2; 1 h	APIM 401s counted separately
KQL-06/06b	Resource-specific + custom	Pipeline names only	SLO-04; partner window	P1/P2; 5–15 min	Failed test run
KQL-07	Custom	Codes and counts	SLO-06	P1/P2; 15 min	Quarantine synthetic items
KQL-08	Custom	HMAC tokens only	SLO-07	P1; per replay	Replay test with seeded duplicate
KQL-09/10	Custom + App Insights	Never returns text	Control failure	P1; 1 h	Seeded synthetic leak string

Table A2. Custom table schemas (metadata only).

Table	Columns
IngestLedger_CL	TimeGenerated, PartnerId, BatchId, CorrelationId, Stage (Received, Enqueued, Dequeued, Persisted, Quarantined, QuarantineResolved, Imported, Reconcile, Replayed), Result, FailureClass, FailureCode, FailureDetail (fixed code text, ≤200 chars), ItemCount, EndToEndSeconds, ResourceType, BusinessKeyToken and ResourceIdToken (HMAC-SHA256, key in Key Vault), ReplayId; Reconcile rows add WindowStart, Received, Accepted, ValidationRejected, OtherFailed, InFlight
AutomationAudit_CL	TimeGenerated, AutomationId, CorrelationId, IncidentId, AlertId, Action, TargetResourceId, PartnerId, ItemCount, TouchesEphiSystem, ApprovalRequired, ApprovalId, ApproverObjectId, ApprovalExpiry, ExecutorObjectId, PreCheck, PostCheck, Result, RollbackRef, Notes (fixed text)

B. Pipeline configuration (completed template)

```
{
  "templateStatus": "Design-time configuration; environment values remain placeholders (no production IDs)",
  "reviewedDate": "2026-10-11",
  "safety": {
    "syntheticDataOnly": true,
    "prohibitPhiInLogs": true,
    "prohibitSecretsInConfig": true,
    "useManagedIdentity": true,
    "placeholderConvention": "<REPLACE_WITH_...>"
  },
  "pipeline": {
    "name": "pl_p001_hl7v2_to_fhir",
    "purpose": "Northwind re-export, backfill and approved replay (real-time path is MLLP listener + Functions, D-08)",
    "owner": "Integration Engineering",
    "criticality": "Tier 1",
    "correlationId": "@pipeline().RunId (mapped to partner correlationId in IngestLedger_CL)",
    "parameters": {
      "partnerId": { "type": "string", "defaultValue": "P-001" },
      "sourcePath": { "type": "string", "defaultValue": "<ENCRYPTED_SOURCE_PATH>" },
      "batchId": { "type": "string", "defaultValue": "<BATCH_ID>" },
      "replayAuthorized": { "type": "bool", "defaultValue": false },
      "approvalId": { "type": "string", "defaultValue": "" },
      "itemCount": { "type": "int", "defaultValue": 0 },
      "partnerLimit": { "type": "int", "defaultValue": 10000 }
    },
    "connectivity": {
      "pattern": "Self-hosted IR (2 nodes, Northwind site) over S2S VPN to ADF private endpoint; Azure side via managed VNet private
endpoints",
      "integrationRuntime": "shir-p001-ha",
      "publicNetworkAccess": "Disabled",
      "privateDnsValidated": true
    },
    "identity": {
      "authentication": "ManagedIdentity",
      "principal": "ADF system-assigned managed identity",
      "rbacAssignments": [
        { "scope": "<SOURCE_SCOPE> (SHIR file share; Windows ACL read-only)", "role": "Read (partner-granted)" },
        { "scope": "<STAGING_SCOPE> (staging container)", "role": "Storage Blob Data Contributor" },
        { "scope": "<QUARANTINE_SCOPE> (quarantine container)", "role": "Quarantine Writer (custom, no delete)" },
        { "scope": "<FHIR_SCOPE>", "role": "FHIR Data Converter; FHIR Data Importer" }
```

```
      ],
      "keyVaultUse": "SHIR authentication key only (EX-05); no secret is read by the pipeline"
    },
    "activities": [
      {
        "name": "GateReplay",
        "type": "IfCondition",
        "expression": "@and(pipeline().parameters.replayAuthorized, and(not(empty(pipeline().parameters.approvalId)),
lessOrEquals(pipeline().parameters.itemCount, pipeline().parameters.partnerLimit)))",
        "onFalse": "Fail REPLAY_NOT_APPROVED"
      },
      {
        "name": "AcquireInput",
        "type": "Copy",
        "input": "Northwind re-export file share via shir-p001-ha",
        "output": "Encrypted staging container (quarantineable)",
        "logging": { "includePayload": false, "includeIdentifiers": false },
        "retry": { "count": 3, "intervalSeconds": 30, "strategy": "exponential-backoff-with-jitter", "onlyTransientErrors": true },
        "timeout": "00:20:00"
      },
      {
        "name": "ConvertToFhirR4",
        "type": "WebOrFunction",
        "operation": "$convert-data",
        "sourceFormat": "HL7v2",
        "templateCollection": "<ACR_LOGIN_SERVER>/hl7v2-northwind@sha256:<APPROVED_DIGEST>",
        "versionGate": "Z-segment version -> digest map; unknown version = UNKNOWN_TEMPLATE_VERSION",
        "logging": { "includePayload": false, "includeIdentifiers": false },
        "onValidationFailure": "Quarantine"
      },
      {
        "name": "ValidateFhir",
        "type": "ValidationGate",
        "profiles": [ "<US_CORE_PROFILE_URLS_PINNED_IN_PARTNER_AGREEMENT>" ],
        "terminology": [ "<APPROVED_VALUE_SETS e.g. LOINC for Observation.code>" ],
        "checks": [ "required-fields", "profile-conformance", "terminology", "referential-integrity", "deterministic-id" ],
        "retry": { "count": 0, "reason": "Validation errors are non-transient" }
      },
      {
        "name": "WriteNdjsonStaging",
        "type": "Copy",
        "format": "NDJSON",
        "encryptionAtRest": true,
        "immutability": "None on staging (transient); time-based immutability on quarantine",
        "retentionDays": 7
      },
      {
        "name": "ImportToFhir",
        "type": "Web",
        "operation": "import",
        "mode": "incremental",
        "idempotencyKey": "P-001:<BATCH_ID>",
        "retry": { "count": 3, "intervalSeconds": 60, "strategy": "exponential-backoff-with-jitter", "onlyTransientErrors": true }
      },
      {
        "name": "Reconcile",
        "type": "ValidationGate",
        "checks": [ "source-count", "accepted-count", "quarantine-count", "duplicate-count", "missing-correlation-ids" ],
        "failureAction": "CreateIncidentAndStop"
      }
    ],
    "quarantine": {
      "location": "Private encrypted quarantine container (time-based immutability)",
```

```
      "writeOnceEvidence": "Enabled; disposal only through manual two-person procedure (AUT-11)",
      "requiredMetadata": [ "partnerId", "batchId", "correlationId", "failureCode", "failureStage", "timestamp" ],
      "exclude": [ "raw payload from logs", "secrets", "access tokens" ],
      "replay": {
        "approvalRequired": true,
        "approverRole": "Peer engineer within limit; On-call Lead for multi-batch",
        "maxBatchSize": 10000,
        "chunkSize": 1000,
        "duplicateDetection": "Deterministic ID = hash(partnerId|resourceType|identifier) + ledger read-before-write + KQL-08",
        "postReplayReconciliation": true
      }
    },
    "observability": {
      "diagnosticSettings": [ "ADFPipelineRun", "ADFActivityRun", "FHIR AuditLogs" ],
      "workspace": "<LOG_ANALYTICS_WORKSPACE> (AMPLS, private only)",
      "archive": "<EVIDENCE_STORAGE_ACCOUNT> (immutable)",
      "customDimensions": [ "partnerId", "batchId", "correlationId", "stage", "result" ],
      "forbiddenDimensions": [ "patientName", "mrn", "dateOfBirth", "rawFhirResource", "rawHl7Message", "accessToken" ]
    },
    "automation": {
      "automatic": [ "create incident", "pause new batch acquisition after threshold (<= 30 min)", "route invalid items to quarantine" ],
      "approvalGated": [ "replay", "pause beyond 30 min", "partner workload-identity disable" ],
      "manual": [ "access revocation (human)", "emergency isolation", "retention change", "delete or purge" ],
      "rollback": "RB-INGEST-001 step 5: stop, restore checkpoint, re-quarantine",
      "postActionValidation": "KQL-08 returns no rows; reconciliation balanced",
      "runbookId": "RB-INGEST-001"
    }
  },
  "learnerDecisionRecord": {
    "scenarioFactsUsed": [ "P-001 HL7v2/MLLP, 120 msg/s, replay 10,000 per approval", "Custom Z-segment (INC-2026-041)", "Replay duplicates
(INC-2026-052)", "SHIR single node (C-03)" ],
    "assumptions": [ "A-01 MLLP over TLS", "A-05 resource-specific tables", "A-06 DCR custom tables" ],
    "tradeoffs": [ "ADF kept off the real-time path (D-08)", "Version history grows on replay (D-03)" ],
    "openQuestions": [ "OQ-01", "OQ-06" ],
    "evidence": [ "Contract-test report", "Replay test report", "KQL-08 output" ]
  }
}
```


C. Infrastructure snippets (Bicep)

```
// Key Vault: RBAC permission model, private only, purge protection (CTRL-003)
resource kv 'Microsoft.KeyVault/vaults@2023-07-01' = {
  name: kvName
  location: location
  properties: {
    tenantId: tenant().tenantId
    sku: { family: 'A', name: 'standard' }
    enableRbacAuthorization: true
    enableSoftDelete: true
    softDeleteRetentionInDays: 90
    enablePurgeProtection: true
    publicNetworkAccess: 'Disabled'
    networkAcls: { defaultAction: 'Deny', bypass: 'None' }
  }
}

// Service Bus Premium: no SAS keys, private, zone-redundant, duplicate detection (D-03)
resource sb 'Microsoft.ServiceBus/namespaces@2022-10-01-preview' = {
  name: sbName
  location: location
  sku: { name: 'Premium', tier: 'Premium', capacity: 1 }
  properties: {
    disableLocalAuth: true
    publicNetworkAccess: 'Disabled'
```

```
    minimumTlsVersion: '1.2'
    zoneRedundant: true
  }
}
resource q 'Microsoft.ServiceBus/namespaces/queues@2022-10-01-preview' = {
  parent: sb
  name: 'sbq-p001-inbound'
  properties: {
    maxDeliveryCount: 5
    defaultMessageTimeToLive: 'P7D'
    deadLetteringOnMessageExpiration: true
    lockDuration: 'PT1M'
    requiresDuplicateDetection: true                // MessageId = HMAC(partnerId|MSH-10)
    duplicateDetectionHistoryTimeWindow: 'PT1H'
  }
}

// Worker identity: receive-only on one queue (CTRL-001)
param sbDataReceiverRoleId string   // built-in "Azure Service Bus Data Receiver"
resource rcv 'Microsoft.Authorization/roleAssignments@2022-04-01' = {
  scope: q
  name: guid(q.id, workerPrincipalId, sbDataReceiverRoleId)
  properties: {
    roleDefinitionId: subscriptionResourceId('Microsoft.Authorization/roleDefinitions', sbDataReceiverRoleId)
    principalId: workerPrincipalId
    principalType: 'ServicePrincipal'
  }
}

// Data Factory: managed identity, no public access, managed VNet (REM-01, REM-02)
resource adf 'Microsoft.DataFactory/factories@2018-06-01' = {
  name: adfName
  location: location
  identity: { type: 'SystemAssigned' }
  properties: { publicNetworkAccess: 'Disabled' }
}
resource mvnet 'Microsoft.DataFactory/factories/managedVirtualNetworks@2018-06-01' = {
  parent: adf
  name: 'default'
  properties: {}
}

// FHIR audit logs to workspace (resource-specific) and immutable archive (CTRL-005, A-05)
resource fhirDiag 'Microsoft.Insights/diagnosticSettings@2021-05-01-preview' = {
  scope: fhir          // Microsoft.HealthcareApis/workspaces/fhirservices
  name: 'diag-fhir-audit'
  properties: {
    workspaceId: law.id
    storageAccountId: evidence.id
    logAnalyticsDestinationType: 'Dedicated'
    logs: [ { category: 'AuditLogs', enabled: true } ]
    metrics: [ { category: 'AllMetrics', enabled: true } ]
  }
}
```

Azure Policy (DINE): assigned at the integration management-group scope for `Microsoft.HealthcareApis/workspaces/fhirservices`, ADF and Service Bus. The existence condition requires `logs.enabled == true` and the approved `workspaceId`. The deployment re-creates `diag-fhir-audit` as above, and remediation tasks run on non-compliance (AUT-01). A companion **deny** policy blocks `publicNetworkAccess != Disabled` on in-scope resource types (PC-02), with exemptions recorded only for EX-01.

D. API Management inbound policy (Fabrikam, H6–H7)

```
<!-- {{...}} are API Management named values (no secrets); environment values stay out of this document -->
<policies>
  <inbound>
```

```
    <base />
    <!-- Only conditional create/update and transaction bundles: no DELETE, no $export -->
    <choose>
      <when condition="@(context.Request.Method != "PUT" && context.Request.Method != "POST")">
        <return-response><set-status code="405" reason="Method Not Allowed" /></return-response>
      </when>
    </choose>
    <validate-jwt header-name="Authorization" failed-validation-httpcode="401" require-scheme="Bearer">
      <openid-config url="https://login.microsoftonline.com/{{tenant-id}}/v2.0/.well-known/openid-configuration" />
      <audiences><audience>{{fhir-audience}}</audience></audiences>
      <required-claims>
        <claim name="appid" match="any"><value>{{fabrikam-client-id}}</value></claim>
      </required-claims>
    </validate-jwt>
    <!-- 40 req/s average (PC-10), keyed on the calling app -->
    <rate-limit-by-key calls="2400" renewal-period="60"
        counter-key="@(context.Request.Headers.GetValueOrDefault("Authorization","").AsJwt()?.Claims.GetValueOrDefault("appid","unknown"))" />
    <set-header name="X-Correlation-ID" exists-action="skip"><value>@(context.RequestId.ToString())</value></set-header>
    <!-- Profile validation on write; confirm header support for the deployed FHIR service version -->
    <set-header name="x-ms-profile-validation" exists-action="override"><value>true</value></set-header>
    <set-backend-service base-url="https://{{fhir-private-fqdn}}" />   <!-- resolves to the private endpoint -->
  </inbound>
  <!-- Diagnostics: request/response body bytes = 0; headers logged: X-Correlation-ID only -->
</policies>
```

E. Replay gate and automation audit record

```
// ADF pl_replay: first activity (REM-07). The run fails unless an approved, in-limit replay is requested.
{ "name": "GateReplay", "type": "IfCondition",
  "typeProperties": {
    "expression": { "type": "Expression", "value":
      "@and(pipeline().parameters.replayAuthorized, and(not(empty(pipeline().parameters.approvalId)),
lessOrEquals(pipeline().parameters.itemCount, pipeline().parameters.partnerLimit)))" },
    "ifFalseActivities": [ { "name": "RejectUnapprovedReplay", "type": "Fail",
      "typeProperties": { "message": "Replay blocked: no valid approval", "errorCode": "REPLAY_NOT_APPROVED" } } ] } }

// AutomationAudit_CL record written by F3 (synthetic values; no payloads or identifiers)
{ "AutomationId": "AUT-05", "CorrelationId": "corr-7f3a", "IncidentId": "INC-SYN-0412", "Action": "StartReplay",
  "TargetResourceId": "<ADF_PIPELINE_RESOURCE_ID>/pl_replay", "PartnerId": "P-001", "ItemCount": 2400,
  "TouchesEphiSystem": true, "ApprovalRequired": true, "ApprovalId": "APR-SYN-0091",
  "ApproverObjectId": "obj-003", "ApprovalExpiry": "2026-10-11T16:40:00Z", "ExecutorObjectId": "obj-la-001",
  "PreCheck": "limit-ok;requester!=approver;no-open-P1", "PostCheck": "KQL-08=0;reconciled", "Result": "Succeeded" }
```

F. Incident-to-control traceability

Incident	Root cause	Design response	Alert / query	Runbook	Evidence
INC-2026-014 secret near miss	Legacy linked service; weak secret scanning	MI everywhere; secret removed; push protection; EX register (CTRL-001)	Repo scan alert; role export	RB-ACCESS-001	Revocation ticket; scan report
INC-2026-027 47-min audit gap	Settings removed in resource move; no alert	DINE policy; delete/move alert; 20-min freshness; canary; archive (CTRL-005)	A3, A4 (KQL-03, KQL-04)	RB-AUDIT-001	Policy compliance; KQL-03 history
INC-2026-041 Z-segment drift	Template change not communicated	Digest pinning; contract test; version gate; partner notice (D-02)	A1, A7 by failureCode	RB-INGEST-001	Contract-test report
INC-2026-052 replay duplicates	Unknown outcomes retried; no duplicate check	Deterministic IDs; ledger read-before-retry; approval gate; KQL-08 (D-03, D-04)	A8 (KQL-08); KQL-09	RB-INGEST-001	Replay report; duplicate = 0

G. References

FHIR service diagnostic logs: learn.microsoft.com/azure/healthcare-apis/fhir/fhir-service-diagnostic-logs

FHIR $convert-data: learn.microsoft.com/azure/healthcare-apis/fhir/convert-data-overview

FHIR $import (initial and incremental mode): learn.microsoft.com/azure/healthcare-apis/fhir/import-data

ADF self-hosted integration runtime: learn.microsoft.com/azure/data-factory/create-self-hosted-integration-runtime

ADF managed virtual network and private endpoints: learn.microsoft.com/azure/data-factory/managed-virtual-network-private-endpoint

Key Vault Azure RBAC guide: learn.microsoft.com/azure/key-vault/general/rbac-guide

Managed identities overview: learn.microsoft.com/entra/identity/managed-identities-azure-resources/overview

Azure Monitor data security: learn.microsoft.com/azure/azure-monitor/logs/data-security

HHS HIPAA Security Rule (45 CFR Part 164, Subpart C): hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html

Security Rule NPRM (published 6 Jan 2025) not finalized; Unified Agenda final action July 2027: hklaw.com/en/insights/publications/2026/07/hipaa-security-rule-amendments-now-projected-for-july-2027; hipaajournal.com/hipaa-updates-hipaa-changes (updated Aug 2026)

Azure API for FHIR retirement, 30 Sep 2026: azure.microsoft.com/updates/azure-api-for-fhir-retirement

NIST SP 800-61 Rev. 2, Computer Security Incident Handling Guide: csrc.nist.gov/pubs/sp/800/61/r2/final